

Cybersecurity 101

Desk Reference & Job Aid — the core vocabulary, principles, and workflow every member of the cyber workforce needs on day one.

The CIA Triad — the goal of all security

Confidentiality — information is disclosed only to those authorized. Protected by access control, encryption, need-to-know.

Integrity — information and systems are accurate and unaltered except by authorized action. Protected by hashing, change control, logging.

Availability — systems and data are usable when needed. Protected by redundancy, backups, resilience, DoS defense.

Every control ultimately serves one or more of these three.

Core vocabulary

Asset — something of value to protect (data, system, service).

Threat — a potential cause of harm (actor or event).

Vulnerability — a weakness a threat can exploit.

Risk — the likelihood a threat exploits a vulnerability × the impact if it does.

Control (safeguard) — a measure that reduces risk.

Likelihood × Impact = Risk. Controls lower likelihood, impact, or both.

Foundational principles

Defense in depth — layered controls; no single failure is fatal.

Least privilege — grant the minimum access needed, no more.

Need to know — access follows a legitimate mission need.

Separation of duties — split critical actions across people.

Fail secure — when something breaks, default to the safe/denied state.

Assume breach — design to detect, contain, and recover, not only to prevent.

AAA — proving and tracking identity

Authentication — proving who you are (something you know / have / are; MFA combines factors).

Authorization — what you are permitted to do once authenticated.

Accounting (audit) — recording what was done, by whom, when.

Common threats to recognize

Phishing / social engineering — manipulating people to give access or information. Verify, don't trust; report suspicious messages.

Malware — ransomware, trojans, worms, spyware. Patch, restrict execution, back up offline.

Credential theft — stolen or reused passwords. Use MFA and unique passphrases.

Insider threat — misuse by trusted users. Least privilege, monitoring, separation of duties.

Misconfiguration & unpatched systems — the most common real-world entry point.

The RMF lifecycle (NIST SP 800-37)

0 • Prepare — context, roles, risk strategy.

1 • Categorize — impact level (FIPS 199: L/M/H for C, I, A).

2 • Select — tailor the SP 800-53 control baseline.

3 • Implement — put controls in place; document how.

4 • Assess — test that controls work as described.

5 • Authorize — AO accepts risk and issues the ATO.

6 • Monitor — continuous monitoring; changes feed back in.

Who does what

AO (Authorizing Official) — accepts risk; signs the ATO.

ISSM — manages the security program for the organization.

ISSO — day-to-day security of a specific system; owns the package.

SCA — independently assesses controls; writes the SAR.

System/Data Owner — owns the mission, the system, and its risk.

Everyday hygiene — do this

Use MFA and strong, unique passphrases; never share credentials.

Lock your screen; encrypt data at rest and in transit.

Patch promptly; report anything suspicious immediately.

Handle CUI per its marking; know your incident-reporting path.

When unsure, ask the ISSO before acting — not after.